UNIVERSITY OF ILLINOIS URBANA-CHAMPAIGN

School of Information Sciences
501 E. Daniel St., MC-493
Champaign, IL 61820-6211

September 9, 2024

Before the
U.S. AI Safety Institute
Washington, D.C.

Commentary on Managing Misuse Risk for Dual-Use Foundation Models

Thank you for the opportunity to provide comments to The US AI Safety Institute via the notice of inquiry on "Managing Misuse Risk for Dual-Use Foundation Models" (NIST AI 800-1 ipd). As dual use foundation models are trained on data from a wide variety of contexts to be applied in entirely different contexts, the risks and biases associated with such models require serious oversight informed by empirical research.

We are academic researchers and students in the School of Information Sciences at the University of Illinois at Urbana-Champaign. We write to offer feedback on "Key Challenges in Mapping and Measuring Misuse Risks" and Objectives 6-7, to encourage revisions that better support operationalization of aims and promote AI safety. We look forward to further opportunities to engage with the Institute to provide additional analysis as the rulemaking process evolves.

Introduction

Risk management and intentional interventions to prevent or mitigate misuses of foundation models is critical to ensure AI safety. Building on Executive Order 14110's definition of dual-use foundation models, which exhibit or have the potential to pose "serious risk to security, national economic security, national public health or safety, or any combination of those matters" (EO 14110), it is important to recognize the wide-reaching impacts of such models and their uses, as well as the responsibility for oversight in regulated domains. While some risks are highly domain specific (e.g., Thieme et al., 2023), many reflect generalizable principles (e.g., Bommasani et al., 2021), such as the introduction of social, technical, and emergent biases into sociotechnical systems and their use cases (Friedman & Nissenbaum, 1996).

Model misuse problems span a wide scope, from deliberate uses of AI for malicious purposes to unintended misuses with serious consequences (Marchal et al., 2024). Further the potential to attack models themselves to undermine a wide variety of subsequent use cases or applications and detract from promising contributions of AI models to specific domains (Jo, 2023; Marchal et al., 2024). There is an imperative to protect against the risks associated with misuses, particularly with respect to human rights (Romero Moreno, 2024). Through clear standards, oversight and accountability, mitigation efforts, and transparency, research indicates governance can support appropriate applications of AI (Ulnicane, 2024).

As such, we offer feedback grounded in empirical and conceptual research as to Section 3, "Key Challenges in Mapping and Measuring Misuse Risks," and Section 4, Objectives 6-7.

Challenges Associated with Mapping and Measuring Misuse of Dual-use Foundation Models

Section 3 characterizes key challenges in order to build confidence and justify the recommended mitigation efforts. We commend NIST for this strategy to directly address points of resistance, in a way that largely reflects the scope of published research on risks and associated challenges for identification and evaluation of misuse. We offer comments on 3 of the 7 identified challenges, to point the agency toward relevant research that offers more nuance on these specific challenges.

Challenge 3.2, "Capabilities do not clearly translate across domains," is positive first step in aligning risks with the contextual integrity framework (Nissenbaum, 2004). However, there is substantial evidence that domain-only contextual scoping only reflects certain limitations on translation of training data or models (Nissenbaum, 2019). Other notable aspects of context include time, place, and culture, both reflecting geographic and organizational differences (Sanfilippo & Liu, 2023); purpose reflects an alternative approach that cross-cuts these dimensions of context to ensure applicable models for use cases (Inel et al., 2023; Whang et al., 2023).

Challenge 3.5, "Methods to evaluate safeguards are nascent," is appropriately circumspect, with Appendix B providing a valuable resource on safeguarding. However, analogies to other technology policy enforcement and evaluation approaches might also prove useful with respect to evaluation. Consider longstanding methods to evaluate: insider threats (Al-Ayat et al., 1986), privacy and security (June & Meiga, 2010), risk mitigation standards (Stoneburner et al., 2002), and requirements engineering (Nicolás et al., 2018).

Challenge 3.6, "Evaluating risk may depend on scarce domain expertise," aptly identifies constraints regarding emergent technologies and sensitive domains, but it is also possible to look to interdisciplinarity as a compliment to address this limitation (Mazzocchi, 2019). As with representation in standards making, there is a benefit to diverse stakeholder experiences and types (Balzarova & Castka, 2012); just as lawmakers often lack necessary technical knowledge to regulation innovations without feedback (Moses, 2013), so to do technologists lack policy expertise to propose effective regulations without legal experts (Gellman & Dixon, 2016). We propose that revisions take into account the broader literature as cited in these comments and those of others submitted through this feedback period. Further, we urge the agency to consider the chilling effects of trade secrets and proprietary approaches on appropriate disclosure and transparency (Glaeser, 2018) regarding risks and misuse incidents as may impede AI safety and trust overall.

Responding to Misuse After Deployment

It is important to collect and respond to evidence of post-deployment misuse of models, as articulated in Objective 6, to better understand and model risk, as well as continuously improve risk management. To successfully operationalize such an objective, it is necessary to promote multi-stakeholder monitoring and information sharing. Not only can organizations learn from one another, via formal partnerships, but a communing approach to pooling information can promote legitimacy of AI governance, trust, and safety (Frischmann et al., 2023; Sanfilippo et al., 2021). While there are challenges to cooperation and information exchange, associated with trade secrets (Mylly, 2023; Pedraza-Fariña, 2016) and competition (Shao et al., 2020), knowledge commons approaches are sustainable and feasible (Dekkar & Kuchař, 2021) solutions to collective action problems surrounding security and privacy (Murtazashvili et al., 2022; Shiffman & Gupta, 2013; Shvartzshnaider et al., 2022), among other technology policy compliance and efficacy issues

(Shackelford, 2019). Further, clear articulation of expectations that firms only communicate risks, misuses, and mitigation efforts, coupled with mechanisms to appropriately govern information flow and diffusion, can increase voluntary and compelled participation (Frischmann et al., 2023; Sanfilippo et al., 2021; Shvartzshnaider et al., 2022).

Practice 6.1, which states "Where possible, monitor distribution channels for evidence of misuse," guides implementation relative to six key recommendations and a suggested documentation approach to provide transparency. Such recommendations are extraordinarily important to ensure timely responses to misuse, or its mitigation, much less the prevention of misuse (Javadi et al., 2021). However, the implied conditionality of monitoring presumes public channels may inform monitoring efforts and that detection methods within individual firms would be sufficient for such efforts. Unfortunately, there is significant evidence that siloing such approaches to monitoring are less effective than collaborative approaches or support regarding misuse and its detection (). We suggest the agency consider how they might support such efforts or provide infrastructure for communication and exchange among organizations.

Practice 6.2, which states "Maintain a process to respond to incidents of model misuse," again places the burden of operationalization entirely on individual organizations which is likely to yield inequality in approaches and efficacy, as well as frustration and challenges within firms (Syed Abdullah et al., 2010). While flexibility allows for contextual specificity (Choung et al., 2024), it is important to make recommendations or provide parameters for protocols in order to ensure processes are effective and efficient. It is the role of public agencies to coordinate such efforts in technical governance compliance (Murphy, 2001). Further, relative to Practice 6.2, Recommendation 4 should also include language that identifies and includes all stakeholders. Drills should be run in collaboration with all engaged groups. While different entities may take on different roles in identifying and responding to misuse, drills and frameworks should not be developed in isolation of other said entities. Regarding federal agencies that should be involved in such matters, we recommend the Cyber Safety Review Board (CSRB) and the Cybersecurity and Infrastructure Security Agency (CISA).

Transparency About the Risks of Misuse

"Providing appropriate transparency about misuse risk," as stated in Objective 7, reflects another key tenet of responsible and safe AI deployment. Research emphasizes transparency as fundamental to public trust and mistrust in AI systems (e.g., Von Eschenbach, 2021), with explainability as one approach to meaningful AI transparency in contrast with black box abstractions or defenses behind trade secrets (Brevini & Pasquale, 2020; Dwivedi et al., 2023). As written, the objective provides for "transparency to the public and relevant entities" which falls short of explainability and leaves significant room for interpretation. We recommend resources and analogous transparency and accountability approaches that might improve adherence to this section.

Practice 7.1, "Publish regular transparency reports that include key details regarding misuse risks and how those risks are managed," offers the most detail as to the current vision for what information is necessary to disclose, but not to whom. As research indicates, transparency, as one component of fairness, accountability, transparency, and ethics (FATE), is key to public trust and safety around AI (Feltzman et al., 2019; Inuwa-Dutse, 2023). However, availability of such a report does not guarantee interpretability or meaningful transparency (de Fine Licht & de Fine Licht, 2020). Further, within 7.1.6 the lack of guidance on what should be included in transparency reports or greater specificity of "regular basis" do not promote accountability or support clear implementation. This requires further clarification and guidance.

Practice 7.2, "Disclose information about risk management practices to promote accountability," importantly emphasizes the need to disclose risk management information to stakeholders who are "effectively independent from the development and deployment process" and "empowered to provide

accountability." Building on accountability research (Novelli et al., 2024), including beyond the sphere of AI ethics and safety (e.g., Babich & Mityuchenko, 2016; Choffnes et al., 2023), this is an important principle. In addition to the recommendation that organizations document "the list of stakeholders that receive information about risk management practices, and the types of information disclosed to them," it would be helpful to recommend what types of roles might meet those aspirational goals of independence. Looking to other technological risk management approaches and literature offer myriad roles and solutions (Ozlati & Yampolskiy, 2017; Somer & Thalmann, 2023; Zekos & Zekos, 2021).

With respect to Practice 7.3, "Report incidents and hazards related to the foundation model to AI incident databases," there is ambiguity regarding to which incident database an organization ought to report or what details must be included. There is significant opportunity to learn from other incident databases, including to incorporate clear and operationalizable guidance on how to make such a repository and transparency effort useful to others. For example, content analysis of the AI Incident Database (Wei & Zhou, 2023), which aims to prevent iteration on AI failures by cataloging incidents and maintain appropriate transparency (McGregor, 2021), highlighted contextual differences across 13 application areas and 8 forms of ethical issues that lead to such incidents but were not uniformly recorded. Wei and Zhou (2023) have developed a taxonomy which provides a structured vocabulary and framework to better support usability of an AI incident database, whether it be the existing database or a new open repository under the purview of your agency.

Summary of Recommendations

Through these comments, we aim to provide empirical support and clarity for the approaches that NIST and the U.S. AI Safety Institute are promoting to manage risks associated with dual-use foundation models. We specifically point to interdisciplinary research literature to support our comments and concerns. We believe it is most important in revisions to clarify transparency requirements, relevant stakeholders and responsibilities, and operationalization and implementation details.

Thank you for your consideration of our comments and suggestions.

Respectfully submitted,

Madelyn Rose Sanfilippo, Assistant Professor
Rhea Rajesh, Undergraduate Student
Sarah Wheeler, Undergraduate Student
Zachary Kilhoffer, PhD Candidate
Kyrie Zhixuan Zhou, PhD Candidate

References

Al-Ayat, R. A., Judd, B. R., & Renis, T. A. (1986). *Safeguards Evaluation Method for evaluating vulnerability to insider threats* (No. UCRL-94162; CONF-860654-28). Lawrence Livermore National Lab., CA (USA).

Babich, O. V., & Mityuchenko, L. S. (2016). Role of accountability management in activity of industrial enterprises. *International Review of Management and Marketing*, *6*(6), 1-6.

Balzarova, M. A., & Castka, P. (2012). Stakeholders' influence and contribution to social standards development: The case of multiple stakeholder approach to ISO 26000 development. *Journal of business ethics*, *111*, 265-279.

Bommasani, R., Hudson, D. A., Adeli, E., Altman, R., Arora, S., von Arx, S., ... & Liang, P. (2021). On the opportunities and risks of foundation models. *arXiv preprint arXiv:2108.07258*.

Brevini, B., & Pasquale, F. (2020). Revisiting the Black Box Society by rethinking the political economy of big data. *Big Data & Society*, *7*(2), 2053951720935146.

Choffnes, D., Hartzog, W., Jordan, S., Markopoulou, A., & Shafiq, Z. (2023). AScientific APPROACH TO TECH ACCOUNTABILITY. *Harvard Journal of Law & Technology*, *37*(3).

Choung, H., David, P., & Seberger, J. S. (2024). A multilevel framework for AI governance. In *The Routledge Handbook of Global and Digital Governance Crossroads* (pp. 310-323). Routledge India.

de Fine Licht, K., & de Fine Licht, J. (2020). Artificial intelligence, transparency, and public decision-making: Why explanations are key when trying to produce perceived legitimacy. *AI & society*, *35*, 917-926.

Dekker, E., & Kuchař, P. (Eds.). (2021). *Governing markets as knowledge commons*. Cambridge University Press.

Dwivedi, R., Dave, D., Naik, H., Singhal, S., Omer, R., Patel, P., ... & Ranjan, R. (2023). Explainable AI (XAI): Core ideas, techniques, and solutions. *ACM Computing Surveys*, *55*(9), 1-33.

Felzmann, H., Villaronga, E. F., Lutz, C., & Tamò-Larrieux, A. (2019). Transparency you can trust: Transparency requirements for artificial intelligence between legal norms and contextual concerns. *Big Data & Society*, *6*(1), 2053951719860542.

Friedman, B., & Nissenbaum, H. (1996). Bias in computer systems. *ACM Transactions on information systems (TOIS)*, *14*(3), 330-347.

Frischmann, B. M., Madison, M. J., & Sanfilippo, M. R. (Eds.). (2023). *Governing smart cities as knowledge commons*. Cambridge University Press.

Glaeser, S. (2018). The effects of proprietary information on corporate disclosure and transparency: Evidence from trade secrets. *Journal of Accounting and Economics*, *66*(1), 163-193.

Gellman, R., & Dixon, P. (2016). Failures of privacy self-regulation in the United States. *Enforcing Privacy: Regulatory, Legal and Technological Approaches*, 53-77.

Inel, O., Draws, T., & Aroyo, L. (2023, November). Collect, measure, repeat: Reliability factors for responsible AI data collection. In *Proceedings of the AAAI Conference on Human Computation and Crowdsourcing* (Vol. 11, No. 1, pp. 51-64).

Inuwa-Dutse, I. (2023, October). FATE in AI: Towards Algorithmic Inclusivity and Accessibility. In *Proceedings of the 3rd ACM Conference on Equity and Access in Algorithms, Mechanisms, and Optimization* (pp. 1-14).

Javadi, S. A., Norval, C., Cloete, R., & Singh, J. (2021, July). Monitoring AI services for misuse. In *Proceedings of the 2021 AAAI/ACM Conference on AI, Ethics, and Society* (pp. 597-607).

Jo, A. (2023). The promise and peril of generative AI. *Nature*, *614*(1), 214-216.

June, W., & Meiga, L. N. (2010). Information technology offshore outsourcing security risks and safeguards. *Journal of Information Privacy and Security*, *6*(3), 29-46.

Marchal, N., Xu, R., Elasmar, R., Gabriel, I., Goldberg, B., & Isaac, W. (2024). Generative AI Misuse: A Taxonomy of Tactics and Insights from Real-World Data. *arXiv preprint arXiv:2406.13843*.

Mazzocchi, F. (2019). Scientific research across and beyond disciplines: Challenges and opportunities of interdisciplinarity. *EMBO reports*, *20*(6), e47682.

McGregor, S. (2021, May). Preventing repeated real world AI failures by cataloging incidents: The AI incident database. In *Proceedings of the AAAI Conference on Artificial Intelligence*, 35(17), 15458-15463).

Moses, L. B. (2013). How to think about law, regulation and technology: Problems with 'technology'as a regulatory target. *Law, Innovation and Technology*, *5*(1), 1-20.

Murphy, D. E. (2001). The federal sentencing guidelines for organizations: A decade of promoting compliance and ethics. *Iowa L. Rev.*, *87*, 697.

Murtazashvili, I., Murtazashvili, J. B., Weiss, M. B., & Madison, M. J. (2022). Blockchain networks as knowledge commons. *International Journal of the Commons*, *16*(1), 108-119.

Mylly, U. M. (2023). Transparent AI? Navigating between rules on trade secrets and access to information. *IIC-International Review of Intellectual Property and Competition Law*, *54*(7), 1013-1043.

Nicolás, J., De Gea, J. M. C., Nicolas, B., Fernandez-Aleman, J. L., & Toval, A. (2018). On the risks and safeguards for requirements engineering in global software development: Systematic literature review and quantitative assessment. *IEEE Access*, *6*, 59628-59656.

Nissenbaum, H. (2004). Privacy as contextual integrity. *Wash. L. Rev.*, *79*, 119.

Nissenbaum, H. (2019). Contextual integrity up and down the data food chain. *Theoretical inquiries in law*, *20*(1), 221-256.

Novelli, C., Taddeo, M., & Floridi, L. (2024). Accountability in artificial intelligence: what it is and how it works. *Ai & Society*, *39*(4), 1871-1882.

Ozlati, S., & Yampolskiy, R. (2017, March). The formalization of AI risk management and safety standards. In *Workshops at the Thirty-First AAAI Conference on Artificial Intelligence*.

Pedraza-Fariña, L. G. (2016). Spill your (trade) secrets: knowledge networks as innovation drivers. *Notre Dame L. Rev.*, *92*, 1561.

Romero Moreno, F. (2024). Generative AI and deepfakes: a human rights approach to tackling harmful content. *International Review of Law, Computers & Technology*, 1-30.

Sanfilippo, M. R., & Liu, C. (2023). Governing Privacy as Contexts Overlap during Crisis. In *The Usage and Impact of ICTs during the Covid-19 Pandemic* (pp. 46-64). Routledge.

Sanfilippo, M. R., Frischmann, B. M., & Strandburg, K. J. (Eds.). (2021). *Governing privacy in knowledge commons*. Cambridge University Press.

Shao, Z., Yuan, S., & Wang, Y. (2020). Institutional collaboration and competition in artificial intelligence. *IEEE Access*, *8*, 69734-69741.

Shackelford, S. J. (2019). Governing the internet of everything. *Cardozo Arts & Ent. LJ*, *37*, 701.

Shiffman, G. M., & Gupta, R. (2013). Crowdsourcing cyber security: a property rights view of exclusion and theft on the information commons. *International Journal of the Commons*, *7*(1), 92-112.

Shvartzshnaider, Y., Sanfilippo, M. R., & Apthorpe, N. (2022). GKC-CI: A unifying framework for contextual norms and information governance. *Journal of the Association for Information Science and Technology*, *73*(9), 1297-1313.

Somer, P., & Thalmann, S. (2023). Risk Management of AI in Industry: a Literature Review. *MCIS 2023 Proceedings*. 27. https://aisel.aisnet.org/mcis2023/27

Stoneburner, G., Goguen, A., & Feringa, A. (2002). Risk management guide for information technology systems. *Nist special publication*, *800*(30), 800-30.

Syed Abdullah, N., Sadiq, S., & Indulska, M. (2010). Emerging challenges in information systems research for regulatory compliance management. In *Advanced Information Systems Engineering: 22nd International Conference, CAiSE 2010, Hammamet, Tunisia, June 7-9, 2010. Proceedings 22* (pp. 251-265). Springer Berlin Heidelberg.

Thieme, A., Nori, A., Ghassemi, M., Bommasani, R., Andersen, T. O., & Luger, E. (2023, April). Foundation models in healthcare: opportunities, risks & strategies forward. In *Extended Abstracts of the 2023 CHI Conference on Human Factors in Computing Systems* (pp. 1-4).

Ulnicane, I. (2024). Governance fix? Power and politics in controversies about governing generative AI. *Policy and Society*, puae022.

Von Eschenbach, W. J. (2021). Transparency and the black box problem: Why we do not trust AI. *Philosophy & Technology*, *34*(4), 1607-1622.

Wei, M., & Zhou, Z. (2023). AI Ethics Issues in Real World: Evidence from AI Incident Database. In *Proceedings of the 56th Hawaii International Conference on Systems Sciences,* 56, 4923-4932.

Whang, S. E., Roh, Y., Song, H., & Lee, J. G. (2023). Data collection and quality challenges in deep learning: A data-centric ai perspective. *The VLDB Journal*, *32*(4), 791-813.

Zekos, G. I., & Zekos, G. I. (2021). AI Risk Management. *Economics and Law of Artificial Intelligence: Finance, Economic Impacts, Risk Management and Governance*, 233-288.

UNIVERSITY OF ILLINOIS URBANA-CHAMPAIGN

217.333.3280 • ischool@illinois.edu • ischool.illinois.edu